



Subversion 1.6 Security Improvements Illustrated

Subversion 1.6.0 was released on 20th March, 2009 and included a lot of security improvements, which we explore in detail in this article.

Last month, while discussing some of the new and significant features available in Subversion 1.6, we talked a little bit about the security features. This month we'll concentrate exclusively on security improvements.

Warning when passwords are cached in plain text

The Subversion client always had capabilities to cache passwords provided by the user in the `~/.subversion` directory in *NIX systems. Unfortunately, these passwords were cached in plain text form, which the user is not explicitly intimated about. Subversion 1.6 throws a prompt before storing passwords in plain text if it is unable to locate a mechanism to encrypt passwords provided by the operating system. This is illustrated as follows:

```
$ svn co http://localhost/svn/repos wc
Authentication realm: <http://localhost:80> TEST SVN repository
Password for 'stylesen':
```

ATTENTION! Your password for authentication realm:

```
<http://localhost:80> TEST SVN repository
```

can only be stored to disk unencrypted! You are advised to configure your system so that Subversion can store passwords encrypted, if possible. See the documentation for details.

You can avoid future appearances of this warning by setting the value of the 'store-plaintext-passwords' option to either 'yes' or 'no' in `'/home/stylesen/.subversion/servers'`.

```
Store password unencrypted (yes/no)? yes
Checked out revision 0.
$
```

The default behaviour is to prompt the user if passwords are going to be stored in plain text. If you don't want to be prompted each time, then you can opt to specify this information in the Subversion servers

configuration file, either globally or on a per-server basis, with the following parameters:

```
Globally,
[global]
store-passwords = yes
store-plaintext-passwords = yes

Per server,
[groups]
group1 = *.collab.net
othergroup = *.example.com

[group1]
store-passwords = yes
store-plaintext-passwords = yes
[othergroup]
store-passwords = no
store-plaintext-passwords = yes
```

We already have mechanisms built in Subversion to cache passwords in encrypted form using the wincrypt API in Windows and Keychain services in Mac OS.

Caching SSL client certificate passphrases

The new version provides a way to cache SSL client certificate passphrases also. Previously, you had an option to specify the client certificate passphrase in the servers file, where you needed to hard-code the passphrase for each SSL client certificate with the parameter `ssl-client-cert-pp`. Now Subversion automatically caches this for each certificate. This feature is analogous to caching passwords, where you are prompted before storing the passphrases in plain text, as explained in the above section. You can also have control over the plain text passphrase caching with the following parameters in the Subversion servers file:

```
store-ssl-client-cert-pp = (yes/no)
store-ssl-client-cert-pp-plaintext = (yes/no)
```